MunichTech GmbH

INFORMATION SECURITY MANAGEMENT SYSTEM INFORMATION SECURITY POLICY

Document Reference	MT-ISMS-POL-001
Version	1.2
Effective Date	[Date]
Prepared By	Austin Bond, Junior GRC Consultant
Reviewed By	[Senior GRC Partner Name], CISM, ISO LA
Approved By	CEO / Managing Director, MunichTech GmbH
Confidentiality Level	**INTERNAL —** All Staff

Version	*Date*	*Author*	*Change Description*
1.0	[Date]	Austin Bond	Initial policy creation; approved by executive leadership in conjunction with ISMS establishment
1.2	[Date]	Austin Bond	Citation correction: BaFin BAIT, withdrawn when DORA (Reg. (EU) 2022/2554) became applicable on 17 January 2025, replaced with DORA references. No policy requirement or control changed.
1.1	[Date]	Austin Bond	Currency update: NIS-2 obligations restated against the BSIG as amended by the NIS-2-Umsetzungsgesetz (BGBl. 2025 I Nr. 301); entity classification corrected to wichtige Einrichtung under Sec. 28(2) BSIG, Anlage 1.

Table of Contents

1. Purpose
2. Scope
3. Executive Policy Statement
4. Information Security Principles
5. Regulatory and Compliance Obligations
6. Roles and Responsibilities
7. Information Security Objectives
8. Risk Management Commitment
9. Compliance and Consequences
10. Communication and Awareness
11. Review and Maintenance
12. Sign-Off

1. Purpose

This Information Security Policy establishes the executive mandate, guiding principles, and accountability framework for information security at MunichTech GmbH. It represents the formal commitment of MunichTech GmbH's leadership to protecting the confidentiality, integrity, and availability of all information assets entrusted to the organization by its clients, employees, and partners.

This policy has been established in accordance with ISO/IEC 27001:2022 Clause 5.2 and constitutes the top-level governance document of the MunichTech GmbH Information Security Management System (ISMS). All subsidiary policies, standards, procedures, and controls derive their authority from this document.

2. Scope

This policy applies to:

- All employees of MunichTech GmbH, including permanent staff, fixed-term contractors, and temporary workers, regardless of location or working arrangement
- All third-party suppliers, subprocessors, and partners who access, process, or handle MunichTech GmbH information assets or systems, as governed by contractual Data Processing Agreements (Auftragsverarbeitungsvertrag / AVV)
- All information assets — digital and physical — owned, leased, or processed by MunichTech GmbH, including client financial data, source code, infrastructure configurations, and internal business data
- All systems and environments defined within the ISMS scope boundary as documented in MT-ISMS-SCO-001, including the AWS Frankfurt Region (eu-central-1) production environment and the MunichTech GmbH principal office in Munich, Bavaria, Germany

3. Executive Policy Statement

MunichTech GmbH operates at the intersection of financial data and cloud technology. Our enterprise clients — banks, asset managers, and financial services institutions — entrust us with their most sensitive operational data. This trust is the foundation of our business and the primary driver of our security obligations.

The Managing Directors of MunichTech GmbH hereby commit to the following:

"MunichTech GmbH is committed to protecting the confidentiality, integrity, and availability of all information it holds — on behalf of its clients, its employees, and itself. We will implement, operate, monitor, review, and continually improve an Information Security Management System that is proportionate to the risks we face, aligned with our legal and regulatory obligations, and embedded in the way we work every day.

Information security is not the sole responsibility of the IT or security function. It is a shared organizational responsibility, and this leadership team holds itself and every member of our organization accountable for upholding it."

— CEO / Managing Director, MunichTech GmbH

Effective: [Date]

4. Information Security Principles

MunichTech GmbH's approach to information security is governed by the following core principles. These principles inform all control design, risk treatment decisions, and security investment prioritization.

#	*Principle*	*Operational Meaning at MunichTech GmbH*
1	Confidentiality	Client financial data is accessed only by authorized individuals with a documented business need. Access is enforced technically, not assumed behaviorally
2	Integrity	Data processed by the MunichTech GmbH platform is accurate, complete, and protected from unauthorized modification — in transit, at rest, and in processing
3	Availability	The MunichTech GmbH SaaS platform is available to clients in accordance with contractual SLA commitments, supported by documented business continuity and disaster recovery capabilities
4	Risk-Based Decision Making	Security controls are selected and prioritized based on documented risk assessments, not assumption. The organization’s risk appetite (MT-ISMS-SCO-001, Section 7) anchors all treatment decisions
5	Security by Design	Information security requirements are integrated into the software

		development lifecycle from inception, not applied retrospectively. Secure development standards (OWASP, SAST/DAST) are non-negotiable gates in the CI/CD pipeline
6	Least Privilege	All users — internal and external — are granted the minimum level of access required to perform their function. Privileged access is subject to enhanced controls and regular review
7	Accountability	Every information asset has a defined owner. Every security control has a defined responsible party. Ambiguity in ownership is treated as a risk in its own right
8	Continual Improvement	The ISMS is not a static certification exercise. Internal audits, incident learnings, threat intelligence, and management reviews drive ongoing maturity improvement
9	Legal and Regulatory Compliance	MunichTech GmbH meets all applicable legal, regulatory, and contractual obligations as a baseline — not a ceiling — for its security posture
10	Human-Centered Security	Employees are MunichTech GmbH's most important security asset and its most significant risk vector. Investment in security awareness, clear policies, and a blame-free reporting culture is a strategic priority

5. Regulatory and Compliance Obligations

Framework	*Nature*	*Key Obligation*
ISO/IEC 27001:2022	Contractual	Achieve and maintain third-party certification by a DAkkS-accredited certification body as a prerequisite for enterprise client onboarding

EU NIS2 Directive (Directive 2022/2555)	Legal	Registration with BSI as an wichtige Einrichtung (BSIG § 28(2), Anlage 1); implementation of the § 30 BSIG risk-management measures; 24-hour early warning and 72-hour incident notification to BSI under § 32 BSIG; executive management personally accountable under § 38 BSIG
DSGVO / GDPR	Legal	Lawful processing of personal data; Data Processing Agreements (AVV) with all processors; Records of Processing Activities (RoPA) maintenance; 72-hour breach notification to BayLDA
BSI IT-Grundschutz	Supplementary	Referenced as technical implementation guidance, particularly BSI OPS.2.2 (Cloud Usage) and APP.3.1 (Web Applications)
KWG / DORA	Client-Imposed	Security controls must satisfy DORA (Reg. (EU) 2022/2554) expectations as assessed during enterprise client vendor due diligence reviews
BetrVG (Betriebsverfassungsgesetz)	Legal	Any technical system capable of monitoring employee behavior requires prior Betriebsvereinbarung under § 87; HR data systems governed under § 94

6. Roles and Responsibilities

ISO 27001:2022 Clause 5.3 requires that roles relevant to information security are assigned, communicated, and understood. The following accountability framework applies at MunichTech GmbH:

Role	Information Security Responsibility
CEO / Managing Director	Ultimate accountability for the ISMS under § 38 BSIG (NIS2 Art. 20); approves this policy and all material risk treatment decisions; chairs annual Management Review
CISO / IT Security Lead (held by Head of Engineering pending dedicated hire)	Day-to-day operational responsibility for ISMS implementation; owns the Risk Register, vulnerability management program, and incident response capability; reports ISMS performance to executive leadership quarterly
GRC Lead / External Advisor	Manages ISMS documentation, audit program, compliance monitoring, and certification readiness; coordinates NIS2 and DSGVO reporting obligations
Head of Engineering	Responsible for security architecture of the SaaS platform; ensures DevSecOps practices are embedded in SDLC; owns technical control implementation
General Counsel	Owns DSGVO compliance program; maintains RoPA; negotiates and reviews AVV/DPA agreements; coordinates with BayLDA and BSI as required
HR Manager	Owns pre-employment screening, security onboarding, and offboarding processes; liaison with Betriebsrat on all monitoring-related Betriebsvereinbarungen
All Employees	Comply with this policy and all subsidiary policies; complete mandatory security awareness training; report suspected incidents or policy violations promptly via the designated incident reporting channel
Third-Party Suppliers	Comply with contractual security obligations as defined in AVV and Technical Security Addenda; cooperate with MunichTech GmbH security assessments

Note on Key Person Risk: The absence of a dedicated full-time CISO is identified as Risk ID HR-003 in the MunichTech GmbH Risk Register (MT-ISMS-RR-001). This risk is actively managed through external GRC advisory engagement and is subject to quarterly executive review.

7. Information Security Objectives

This policy commits MunichTech GmbH to pursuing the following high-level information security objectives, as defined and measured in MT-ISMS-SCO-001 Section 6:

#	Objective	Owner
1	Protect the confidentiality of client financial data against unauthorized access or disclosure	CISO / Head of Engineering
2	Ensure platform availability meeting contractual SLA commitments (≥ 99.9% monthly uptime)	Head of Engineering / DevOps
3	Achieve and maintain ISO 27001:2022 certification by Q4 2025 with zero major non-conformities	GRC Lead
4	Maintain full compliance with DSGVO and NIS2 obligations with zero overdue notifications	Legal & Compliance
5	Reduce organizational attack surface through continuous vulnerability management (Critical MTTR ≤ 72 hours)	Head of Engineering
6	Build a security-aware organizational culture (phishing simulation click rate < 5%)	HR / GRC Lead

Objectives are reviewed quarterly by the CISO and annually by executive leadership as part of the ISMS Management Review (ISO 27001:2022 Clause 9.3).

8. Risk Management Commitment

MunichTech GmbH commits to a structured, documented, and repeatable risk management process as the foundation of its ISMS, in accordance with ISO 27001:2022 Clause 6.1.

- All information security risks are assessed against the criteria and methodology defined in the MunichTech GmbH Risk Assessment Methodology (MT-ISMS-RAM-001)
- Risk treatment decisions are documented in the Risk Register (MT-ISMS-RR-001) and aligned to the Risk Appetite Statement (MT-ISMS-SCO-001, Section 7)
- Risks assessed as HIGH or CRITICAL that exceed the organization's stated risk appetite require documented, board-approved treatment decisions before acceptance
- The Risk Register is reviewed quarterly by the CISO and updated following any significant incident, material organizational change, or emerging threat intelligence

9. Compliance and Consequences

9.1 Mandatory Compliance

Compliance with this policy and all subsidiary ISMS policies is mandatory for all individuals within scope. This policy is incorporated by reference into all employment contracts and third-party supplier agreements.

9.2 Consequences of Non-Compliance

Party	*Consequence of Non-Compliance*
Employees	Violations may result in disciplinary action up to and including termination of employment, in accordance with the MunichTech GmbH HR disciplinary framework and applicable German labor law (Arbeitsrecht). Disciplinary procedures are governed by the existing Betriebsvereinbarung agreed with the Betriebsrat
Third-Party Suppliers	Material non-compliance with contractual security obligations constitutes grounds for contract termination and may trigger liability under the applicable AVV
Executive Management	Under § 38 BSIG (NIS2 Art. 20), executive management bears personal accountability for ISMS governance failures. Willful disregard of information security obligations may result in personal liability under applicable regulatory enforcement action

9.3 Incident Reporting

All employees are required to report actual or suspected information security incidents — including policy violations, phishing attempts, data loss, and unauthorized access — immediately via the MunichTech GmbH incident reporting channel. A no-blame reporting culture is actively maintained. Failure to report a known incident is itself a policy violation.

10. Communication and Awareness

This policy shall be:

- Communicated to all employees at onboarding and made permanently accessible via the MunichTech GmbH intranet (Confluence: MT-ISMS / Policies)
- Reviewed and acknowledged by all employees annually as part of the mandatory security awareness training program
- Made available to external interested parties — including enterprise clients, DAkkS-accredited auditors, BSI, and BayLDA — upon request and as appropriate to their relationship with MunichTech GmbH
- Translated into German for distribution to all Munich-based employees, in recognition of the working language of the majority of the workforce and in alignment with German employment law expectations

Note on Betriebsrat: Distribution of this policy, and any monitoring-related provisions within subsidiary policies, has been coordinated with the MunichTech GmbH Betriebsrat in accordance with BetrVG § 87. All employee-facing security awareness programs are subject to Betriebsrat information rights under BetrVG § 80.

11. Review and Maintenance

This policy shall be reviewed:

- Annually — as part of the ISMS Management Review cycle (ISO 27001:2022 Clause 9.3)
- Following a significant information security incident that reveals a gap in policy coverage
- Upon material change to the regulatory environment, organizational structure, or technology landscape

Event	*Review Owner*	*Target Completion*
Annual Management Review	GRC Lead + CEO	[Date]
Post-incident review	CISO / GRC Lead	Within 30 days of incident closure
Regulatory change	Legal & Compliance	Within 60 days of published update

This policy is maintained under version control in the MunichTech GmbH ISMS Confluence space (MT-ISMS / Policies). Superseded versions are archived in accordance with ISO 27001:2022 Clause 7.5 and DSGVO documentation retention requirements.

DOCUMENT APPROVAL

PREPARED BY	
Name	Austin Bond
Title	Junior GRC Consultant
Date	[Date]
Signature	
REVIEWED BY	
Name	[Senior GRC Partner Name]
Title	Senior GRC Partner, CISM | ISO 27001 Lead Auditor
Date	[Date]
Signature	
APPROVED BY	
Name	[CEO / Managing Director Name]
Title	Chief Executive Officer, MunichTech GmbH
Date	[Date]
Signature	